FinPilot AI

Deterministic Financial Intelligence, Portfolio Telemetry & Autonomous Advisory System

Technical Documentation & Software Architecture Report

Project Name	FinPilot AI: Deterministic Financial Intelligence & Telemetry Platform
Version	2.4.0 (Production Release)
Document Date	28 October 2026
Document ID	FP-TDR-2.4.0-001
Author / Team	FinPilot Engineering Team (Architecture, Security, Quant Systems, Documentation)
Standards Basis	IEEE 1016 (design descriptions), IEEE 29148 (requirements), ISO/IEC 25010 (product quality), ISO/IEC 26514 (user documentation)
Audience	Technical evaluators, enterprise auditors, financial institutions, end-users
Classification	CONFIDENTIAL - Restricted Distribution

WARNING: Confidentiality Notice. This document contains proprietary architecture, security design and algorithmic specifications of FinPilot AI. It is intended solely for the named recipients. Reproduction, disclosure or distribution without written authorisation from FinPilot Engineering is prohibited. If you received this document in error, destroy all copies and notify the author team.

Table of Contents

Table of Contents 2

1. Executive Summary & Problem Statement 4

1.1 Executive Summary . . . 4
1.2 Problem Statement . . . 4
1.3 Core Value Proposition . . . 4
1.4 Quality Objectives (ISO/IEC 25010) . . . 4

2. System Architecture & Technology Stack 5

2.1 Architectural Principles . . . 5
2.2 Technology Stack . . . 5
2.3 Core Engines . . . 5
2.4 Architecture Diagram . . . 6
2.5 Data Flow Summary . . . 6

3. Functional Modules & Specifications 7

Module A: Authentication & Zero-Trust Security Gate . . . 7
Module B: Cashflow & Financial Health Score Engine . . . 7
Module C: Investment Telemetry & Asset Ledger . . . 8
Module D: Goals, SIP & Debt Optimizer . . . 9
Module E: SME & Business Suite . . . 9
Module F: FIA (Financial Intelligence Agent) & Affordability Decision Engine . . . 10
Module G: Stress Testing & Scenario Lab . . . 11

4. Data Models & State Specification 12

4.1 Core Interfaces . . . 12
4.2 Persisted State Envelope . . . 12
4.3 Invariants . . . 13

5. Security, Privacy & Compliance 14

5.1 Client-Side Data Segregation . . . 14
5.2 Biometric Session Protection . . . 14
5.3 Zero Telemetry Leakage . . . 14
5.4 OWASP Top 10 (2021) Alignment . . . 14
5.5 Privacy & Regulatory Mapping . . . 14
5.6 Threat Summary . . . 15

6. Installation, Deployment & Operation Manual 16

6.1 Prerequisites . . . 16

(c) 2026 FinPilot Engineering. All rights reserved.

6.2 Environment Variables 16
6.3 Build Pipeline 16
6.4 Production Deployment 16
6.5 Operations 17
7. User Guide & Walkthrough **18**
7.1 Step-by-Step Walkthrough 18
7.2 Example: FIA Affordability Query 18
7.3 Troubleshooting FAQ 18
7.4 Glossary 19
7.5 Disclaimer 19

Document Revision History

Version	Date	Change Summary	Owner
2.4.0	2026-10-28	Production release: Scenario Lab tenure expansion, hash-chained audit log, WebAuthn session lock	Engineering
2.3.0	2026-08-14	FIA voice bridge, affordability engine, SME GST ledger	Engineering
2.2.0	2026-05-30	SSE quote telemetry, avalanche/snowball optimizer	Engineering
2.0.0	2026-01-20	Deterministic financial engine rewrite (financialEngine.ts)	Architecture

NOTE: Compliance language in this document describes **design alignment** with the cited standards and frameworks. It is not a statement of third-party certification or regulatory approval. Financial output is informational and is not licensed investment advice.

(c) 2026 FinPilot Engineering. All rights reserved.

1. Executive Summary & Problem Statement

1.1 Executive Summary

FinPilot AI is a browser-delivered financial intelligence platform for individuals and small-to-medium enterprises (SMEs). It consolidates cashflow, investments, debt, goals, invoicing and tax tracking into one telemetry surface and layers a conversational agent, the **Financial Intelligence Agent (FIA)**, on top of a **deterministic mathematical core**. Every number the user sees, from the Financial Health Score to a what-if affordability verdict, is computed by pure, unit-tested functions in `financialEngine.ts`. Language models, where used, are restricted to intent parsing and phrasing; they never originate or alter a figure.

Version 2.4.0 is the production release. It delivers seven functional modules, a PIN-protected cryptographic vault, real-time market telemetry over Server-Sent Events (SSE), a voice interface, and a tamper-evident security audit trail.

1.2 Problem Statement

Problem	Description	Consequence
Fragmented finances	Bank balances, brokerage holdings, loans, invoices and tax obligations live in separate apps and spreadsheets; SME owners mix personal and business cash.	No single net-worth or liquidity view; late decisions; duplicated data entry.
No real-time stress testing	Users rarely model an income shock, an emergency withdrawal, or a longer loan tenure before committing to a decision.	Over-leverage; thin emergency runway discovered only during a crisis.
Black-box AI risk	Generic LLM assistants produce fluent but unverifiable arithmetic and can hallucinate rates, balances and rules.	Unauditable advice; unacceptable for regulated institutions and auditors.
Privacy exposure	Cloud aggregators centralise sensitive financial data and transmit it to many third parties.	Breach blast-radius, consent complexity, compliance burden.

1.3 Core Value Proposition

- **Zero-hallucination arithmetic.** All monetary figures originate from deterministic functions: same input, same output, reproducible and testable.
- **Agentic intelligence on a leash.** FIA selects an engine tool, the engine computes, and FIA narrates the result. A numeric guard rejects any narrated figure that does not match the tool output.
- **Proactive risk visibility.** The Scenario Lab stress-tests income, liquidity and debt tenure on demand.
- **Privacy-first by design.** Personal data is segregated client-side and encrypted in a PIN-derived vault; the server proxy is stateless with respect to user financial data.
- **Auditability.** A hash-chained security log makes tampering detectable.

1.4 Quality Objectives (ISO/IEC 25010)

Characteristic	Objective	Primary mechanism
Functional suitability	Correct, complete financial computation	Pure-function engine with property-based tests
Performance efficiency	Full dashboard recompute < 50 ms for 10,000 transactions	Memoised selectors, single-pass aggregation
Reliability	Quote feed degrades gracefully	SSE reconnect with back-off, last-known-good cache
Security	Confidentiality and integrity of local data	AES-GCM vault, PBKDF2, hash-chained audit log
Usability	Task completion without training	Guided flows, inline validation, voice input
Maintainability	Isolated, replaceable engines	Typed module boundaries, no UI imports in engine
Portability	Any evergreen browser, Node 20+	Standards-based Web APIs, containerisable server

(c) 2026 FinPilot Engineering. All rights reserved.

2. System Architecture & Technology Stack

2.1 Architectural Principles

- **Determinism first:** the math engine is side-effect free and has no dependency on React, network, clock or randomness (the evaluation date is injected).
- **Thin server:** the Node.js/Express tier proxies market quotes and serves static assets; it does not store user financial data.
- **Defence in depth:** validation at input, at engine boundary and at storage boundary.
- **Explainability:** each computed metric exposes its formula, inputs and intermediate values.

2.2 Technology Stack

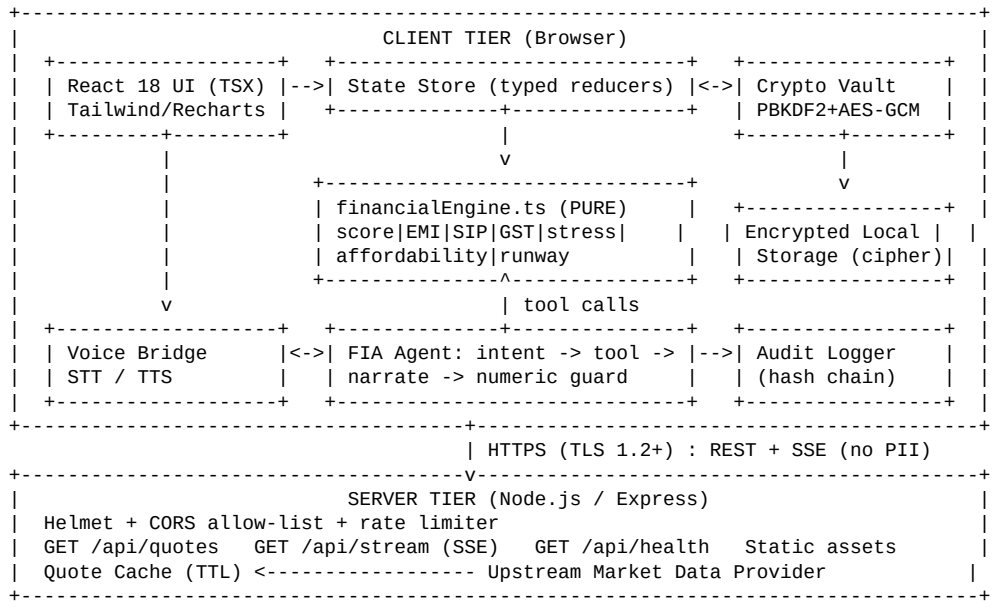
Tier	Technology	Role
Client	React 18, TypeScript (strict)	Component UI, typed state and engine contracts
Client	Vite	Dev server, ES-module bundling, production build
Client	Tailwind CSS	Utility-first design system, responsive layout, dark mode
Client	Lucide Icons	Consistent iconography
Client	Recharts	Cashflow, allocation, amortization and scenario charts
Client	Web Crypto, Web Speech, WebAuthn	Vault crypto, speech recognition / TTS, session lock
Server	Node.js (20 LTS+), Express	Quote proxy, SSE telemetry broadcaster, static hosting
Server	Helmet, CORS allow-list, rate limiter	HTTP hardening and abuse control

2.3 Core Engines

Engine	Location	Responsibility
Deterministic Financial Math Engine	`financialEngine.ts` (client)	Health score, EMI/amortization, SIP, GST, runway, affordability, stress scenarios
Live Quote Feed Proxy	Express route `/api/quotes`, `/api/stream`	Fetches upstream quotes, normalises, caches, pushes via SSE
Voice Bridge	Client service	Speech recognition to intent text; TTS for FIA replies; push-to-talk and mute controls
PIN-Protected Cryptographic Vault	Client service	Derives key from PIN, encrypts/decrypts persisted state, enforces lockout
Security Audit Logger	Client service	Appends hash-chained events; verifies chain integrity

(c) 2026 FinPilot Engineering. All rights reserved.

2.4 Architecture Diagram



2.5 Data Flow Summary

#	Flow	Path	Data crossing network?
1	User entry to computed metric	UI to store to engine to UI	No
2	Persistence	Store to Vault (encrypt) to local storage	No
3	Market telemetry	Upstream to Proxy to SSE to UI	Ticker symbols only inbound; no user data
4	FIA query	Voice/text to intent to engine tool to narrated reply	No raw ledger leaves the device by default
5	Audit	Event to hash chain to encrypted storage	No

> **NOTE:** If an optional hosted language model is enabled for FIA phrasing, only the structured tool result (aggregated figures, no account identifiers) is sent, and this must be explicitly turned on in Settings.

(c) 2026 FinPilot Engineering. All rights reserved.

3. Functional Modules & Specifications

Each module lists its purpose, requirements (IEEE 29148 style: **shall** statements) and algorithmic definition. Currency symbols are configurable; examples use INR-scale numbers.

Module A: Authentication & Zero-Trust Security Gate

Every route except the sign-in screen is guarded. No view renders and no state is decrypted until the user is authenticated and the vault is unlocked. Trust is re-evaluated on inactivity and on sensitive actions.

Req ID	Requirement
A-01	The system shall require a **username** of 3-32 characters (letters, digits, underscore, dot).
A-02	The system shall validate **email** against an RFC 5322 practical subset: local part, single '@', domain labels of 1-63 characters, TLD of at least 2 characters; reject consecutive dots and leading/trailing dots.
A-03	The system shall enforce a **password policy** of at least 6 characters, alphanumeric, containing at least one letter and one digit.
A-04	The system shall require a **numeric PIN** (4-8 digits) to derive the vault key; the PIN is never stored.
A-05	The system shall lock the vault after 5 consecutive PIN failures for an exponentially increasing cool-down (30 s, 1 min, 5 min...).
A-06	The system shall append every security-relevant event to a **tamper-evident audit log**.
A-07	The system shall auto-lock after a configurable idle timeout (default 5 min) and on tab visibility loss if enabled.

```
// Validation rules (authValidators.ts)
export const USERNAME_RE = /^[A-Za-z0-9_.]{3,32}$/;
export const EMAIL_RE =
  /^(?!\.)(?!.*\.\.)[A-Za-z0-9.!#$%&'*+/=?^_`{|}~-]{1,64}(?<!\.)@(?=.{1,255}$)
   ([A-Za-z0-9](?:[A-Za-z0-9-]{0,61}[A-Za-z0-9])?\.)+[A-Za-z]{2,}$/x;
export const isValidPassword = (p: string) =>
  p.length >= 6 && /^[A-Za-z0-9]+$/.test(p) && /[A-Za-z]/.test(p) && /\d/.test(p);
export const isValidPin = (p: string) => /^\d{4,8}$/.test(p);
```

WARNING: The 6-character alphanumeric rule is the **minimum enforced policy**. Institutions are advised to raise the minimum length to 12 via configuration; offline brute-force resistance of the vault depends primarily on PIN entropy and PBKDF2 cost, so a PIN of 6+ digits is recommended.

Audit Log Integrity

Each entry stores `hash = SHA-256(prevHash || canonicalJSON(entry))`. Verification replays the chain from the genesis hash; any edited, removed or reordered entry changes every subsequent hash and is flagged.

Event type	Trigger	Severity
AUTH_REGISTER / AUTH_LOGIN_OK	Account creation, successful sign-in	INFO
AUTH_LOGIN_FAIL / PIN_FAIL	Invalid credentials or PIN	WARN
VAULT_LOCKOUT	Failure threshold reached	ALERT
VAULT_UNLOCK / AUTO_LOCK	Vault state transitions	INFO
DATA_EXPORT / DATA_WIPE	User exports or deletes data	WARN
LOG_INTEGRITY_FAIL	Chain verification mismatch	CRITICAL

Module B: Cashflow & Financial Health Score Engine

Aggregates transactions into monthly cashflow and computes a **Financial Health Score (FHS)** from 0 to 100 using four weighted sub-scores. Let I = monthly income, E = monthly expenses, D = monthly debt service, L = liquid assets, E_{ess} = essential monthly expenses, and clamp(x) bound to [0,1].

(c) 2026 FinPilot Engineering. All rights reserved.

Component	Definition	Sub-score (0-100)	Weight
Savings rate (SR)	(I - E) / I	100 x clamp(SR / 0.20)	30%
Debt-to-income (DTI)	D / I	100 x clamp((0.43 - DTI) / (0.43 - 0.15))	25%
Emergency runway (R)	L / E_{ess} (months)	100 x clamp(R / 6)	25%
Budget adherence (BA)	1 - mean over categories of max(0, actual - budget) / budget	100 x clamp(BA)	20%

FHS = 0.30 S_{SR} + 0.25 S_{DTI} + 0.25 S_{R} + 0.20 S_{BA}, rounded to the nearest integer.

Band	FHS range	Interpretation
Excellent	85-100	Resilient; focus on growth
Good	70-84	Healthy; minor optimisations
Fair	50-69	Gaps in liquidity or leverage
At Risk	0-49	Immediate corrective action advised

```
export const clamp01 = (x: number) => Math.min(1, Math.max(0, x));
export function healthScore(m: { income: number; expenses: number; debtService: number;
  liquid: number; essential: number; budgets: { budget: number; actual: number }[] }) {
  const sr  = m.income > 0 ? (m.income - m.expenses) / m.income : 0;
  const dti = m.income > 0 ? m.debtService / m.income : 1;
  const run = m.essential > 0 ? m.liquid / m.essential : 0;
  const over = m.budgets.length
    ? m.budgets.reduce((a, b) => a + Math.max(0, b.actual - b.budget) / Math.max(b.budget, 1), 0) / m.budgets.length : 0;
  const s = { sr: 100*clamp01(sr/0.20), dti: 100*clamp01((0.43-dti)/0.28),
              run: 100*clamp01(run/6), ba: 100*clamp01(1-over) };
  const score = Math.round(0.30*s.sr + 0.25*s.dti + 0.25*s.run + 0.20*s.ba);
  return { score, sub: s, inputs: { sr, dti, run, over } };
}
```

Worked Example

Income 100,000; expenses 70,000; debt service 25,000; liquid 240,000; essential 50,000; mean overspend 10%. SR = 0.30 gives 100; DTI = 0.25 gives 100 x (0.43-0.25)/0.28 = 64.3; R = 4.8 months gives 80; BA = 0.90 gives 90. **FHS = 30.0 + 16.1 + 20.0 + 18.0 = 84.1, rounded 84 (Good).**

Module C: Investment Telemetry & Asset Ledger

A ledger of holdings across equities, commodities (e.g. gold, silver), mutual funds and cash equivalents with live valuation through the quote proxy.

- The system shall record each lot with symbol, asset class, quantity, unit cost and acquisition date.
- The system shall subscribe to `/api/stream` for the user's symbols only and revalue holdings on each tick.
- The system shall compute market value, unrealised P&L, weighted-average cost, allocation percentage and day change.
- The system shall display a **staleness badge** when the last tick is older than 2 x the refresh interval, and never present stale data as live.

Metric	Formula
Market value	MV = sum(q_i x P_i)
Cost basis	C = sum(q_i x c_i)
Unrealised P&L	MV - C; percentage = (MV - C) / C
Allocation weight	w_k = $MV_{class\ k}$ / MV
Concentration flag	Raised when any single asset has w > 0.35

SSE contract. Events are `event: quote` with JSON payloads. The server sends a heartbeat comment every `SSE_HEARTBEAT_MS`; the client reconnects with exponential back-off (1 s to 30 s).

(c) 2026 FinPilot Engineering. All rights reserved.

```
event: quote
data: {"symbol":"GOLD","price":7421.50,"currency":"INR","ts":"2026-10-28T09:15:02Z","src":"upstream"}
: heartbeat
```

> **NOTE:** Market data is delivered by a configurable upstream provider and may be delayed. It is informational and not executable pricing.

Module D: Goals, SIP & Debt Optimizer

D.1 Goals and SIP Planner

With monthly rate *i* = annual / 12 and *n* months, the future value of a monthly SIP *P* (annuity-due) is **FV = P x [((1+i)^n - 1) / i] x (1+i)**. The required SIP for a target is **P = FV x i / [((1+i)^n - 1)(1+i)]**. If i = 0 then P = FV / n.

Goal contribution telemetry tracks: funded % = saved / target; pace = saved / expected-by-today; projected completion date from trailing 3-month average contribution.

D.2 Loan Amortization

EMI = P x r x (1+r)^n / ((1+r)^n - 1), r = APR / 1200. Each month: interest = balance x r; principal = EMI - interest; balance reduces by principal. The final instalment is adjusted to clear rounding residue.

D.3 Snowball vs. Avalanche

Attribute	Snowball	Avalanche
Priority order	Smallest balance first	Highest APR first
Mathematical optimality	Not interest-optimal	Minimises total interest (for fixed payment pool)
Behavioural benefit	Fast early wins, motivation	Slower first payoff
Mechanism	All minimums paid; surplus plus freed minimums roll to the target debt	Same, with APR ordering

Worked example computed by the engine for three debts (Credit Card A: 40,000 @ 36%, min 2,000; Personal Loan B: 150,000 @ 14%, min 5,000; Consumer Loan C: 25,000 @ 10%, min 1,500) with an extra 5,000 per month:

Strategy	Months to debt-free	Total interest paid
Minimums only (no extra)	38	59,092
Snowball (+5,000)	23	33,645
Avalanche (+5,000)	21	28,371
Avalanche savings vs. snowball	-	5,275

```
export function payoff(debts: Debt[], extra: number, mode: 'snowball' | 'avalanche') {
  const ds = debts.map(d => ({ ...d })); let month = 0, interest = 0;
  while (ds.some(d => d.balance > 0.005) && month < 600) {
    month++; let pool = extra + ds.filter(d => d.balance > 0.005).reduce((a, d) => a + d.minPayment, 0);
    for (const d of ds) if (d.balance > 0.005) { const i = d.balance * d.apr / 1200; d.balance += i; interest += i; }
    for (const d of ds) if (d.balance > 0.005) { const p = Math.min(d.minPayment, d.balance); d.balance -= p; pool -= p;
    const order = ds.filter(d => d.balance > 0.005).sort(mode === 'snowball'
      ? (a, b) => a.balance - b.balance : (a, b) => b.apr - a.apr);
    for (const d of order) { if (pool <= 0) break; const p = Math.min(pool, d.balance); d.balance -= p; pool -= p; }
  }
  return { months: month, totalInterest: interest };
}
```

> **TIP:** Avalanche is optimal for interest cost; where motivation is the limiting factor, snowball may lead to better real-world completion. The optimizer displays both so the user can choose.

Module E: SME & Business Suite

(c) 2026 FinPilot Engineering. All rights reserved.

- **Invoicing:** customer, line items, quantity, rate, discount, tax code, due date, status (Draft, Sent, Partially Paid, Paid, Overdue). Sequential, gap-free numbering per financial year.
- **GST / tax ledger:** output tax on sales, input tax credit (ITC) on purchases, net liability per period.
- **Working-capital runway projection:** forecasts cash months remaining from receivables, payables and burn.

Calculation	Formula
Taxable value	T = sum(qty x rate) - discount
Intra-state GST	CGST = SGST = T x (g / 2); total tax = T x g
Inter-state GST	IGST = T x g
Net GST liability	Output tax - eligible ITC (carry-forward if negative)
Net burn	B = fixed costs + variable costs - collections run-rate
Working capital	WC = cash + p x receivables - payables due within horizon, where p is the collection probability
Runway (months)	WC / B, evaluated if B > 0; otherwise reported as 'cashflow positive'

WARNING: Tax rates, ITC eligibility and filing rules change. Tax rates are configuration data in the ledger, not hard-coded constants, and outputs must be reviewed by a qualified tax professional before filing.

Module F: FIA (Financial Intelligence Agent) & Affordability Decision Engine

FIA is a conversational agent available by text or voice. It follows a strict **tool-grounded** pipeline:

```
User utterance --> Intent classifier --> Tool selection --> financialEngine.ts (pure compute)
                                                                        |
Spoken / written reply <-- Narrator (phrasing only) <-- Numeric Guard <-- structured result
```

- **Numeric Guard:** every number in the draft reply is matched against the tool result (tolerance: rounding only). Mismatch results in the draft being discarded and a templated, deterministic reply used instead.
- **Speech:** Web Speech recognition for input; speech synthesis for output with rate, voice and mute controls. Voice features require microphone permission and degrade to text when unavailable.
- **Refusal policy:** FIA declines requests for guaranteed returns or personalised securities recommendations and states data limitations.

Affordability Decision Engine

For a prospective purchase with price *X*, down payment *d*, financing at APR and tenure *n*, the engine computes post-purchase metrics and applies three tests:

Test	Post-purchase metric	Pass threshold
Leverage	DTI' = (D + EMI) / I	<= 0.40
Liquidity	R' = (L - d) / E_{ess}	>= 3 months
Savings capacity	SR' = (I - E - EMI) / I	>= 0.10

Verdict	Condition
AFFORDABLE	All three tests pass
CAUTION	Exactly one test fails, or any metric within 10% of its threshold
NOT ADVISED	Two or more tests fail

```
export function affordability(p: Profile, x: { price: number; down: number; apr: number; months: number }) {
  const emi = x.apr > 0 ? pmt(x.price - x.down, x.apr / 1200, x.months) : (x.price - x.down) / x.months;
  const dti = (p.debtService + emi) / p.income, run = (p.liquid - x.down) / p.essential;
  const sr = (p.income - p.expenses - emi) / p.income;
  const fails = [dti > 0.40, run < 3, sr < 0.10].filter(Boolean).length;
  return { emi, dti, run, sr, verdict: fails === 0 ? 'AFFORDABLE' : fails === 1 ? 'CAUTION' : 'NOT_ADVISED' };
}
```

(c) 2026 FinPilot Engineering. All rights reserved.

> **NOTE:** Thresholds are defaults in `policy.ts` and may be tuned by institutions; the applied thresholds are always displayed beside the verdict.

Module G: Stress Testing & Scenario Lab

Scenarios are applied to a copy of the user's baseline and compared side by side. Scenarios can be combined.

Scenario	Parameters	Transformation	Outputs
Income shock	drop % h, duration m months	I' = I x (1 - h) for m months	Monthly deficit, months until liquid < 0, FHS delta
Emergency liquidity drawdown	amount W, month t	L' = L - W at month t	Runway change, goal delay
Tenure expansion	new tenure n' for a loan	EMI' recomputed with n'; interest = EMI' x n' - P	Cashflow relief vs. extra interest
Rate shock (floating loans)	+ bps	r' = r + bps / 120000	EMI delta, total interest delta

Survival horizon: the smallest month *k* with $L_k = L_0 + \text{sum}_{j<=k}(I'_j - E - D) < 0$, or > 60 if none (reported as 'resilient beyond 60 months').

```
export function survival(base: Baseline, s: { drop: number; months: number; withdraw?: { amt: number; at: number } }) {
  let liquid = base.liquid;
  for (let k = 1; k <= 60; k++) {
    const inc = k <= s.months ? base.income * (1 - s.drop) : base.income;
    liquid += inc - base.expenses - base.debtService;
    if (s.withdraw && k === s.withdraw.at) liquid -= s.withdraw.amt;
    if (liquid < 0) return { survivesMonths: k - 1, breachMonth: k };
  }
  return { survivesMonths: 60, breachMonth: null };
}
```

(c) 2026 FinPilot Engineering. All rights reserved.

4. Data Models & State Specification

All models are declared in `types.ts`. Monetary amounts are stored as integers in minor units (e.g. paise) to avoid floating-point drift, and rendered through a single formatter.

4.1 Core Interfaces

```
export type ISODate = string;                // 'YYYY-MM-DD' or full ISO-8601
export type Minor = number;                  // integer minor currency units

export interface UserProfile {
  id: string;                                // UUID v4
  username: string;                          // A-01
  email: string;                             // A-02
  passwordVerifier: string;                  // PBKDF2-SHA256 hash (base64), never plaintext
  pinSalt: string;                           // base64, 16 bytes
  kdfIterations: number;                     // >= 310000
  currency: 'INR' | 'USD' | 'EUR' | 'GBP';
  monthlyIncome: Minor;
  mode: 'PERSONAL' | 'SME';
  preferences: { theme: 'light' | 'dark'; voice: boolean; idleLockMin: number };
  createdAt: ISODate;
}

export interface LinkedAccount {
  id: string;
  kind: 'BANK' | 'CARD' | 'BROKERAGE' | 'WALLET' | 'LOAN';
  institution: string;
  maskedNumber: string;                      // last 4 only
  balance: Minor;                            // negative for liabilities
  lastSyncedAt: ISODate;
}

export interface Transaction {
  id: string;
  accountId: string;
  date: ISODate;
  amount: Minor;                             // + inflow, - outflow
  category: 'INCOME' | 'RENT' | 'FOOD' | 'TRANSPORT' | 'UTILITIES' | 'EMI' | 'INVEST' | 'OTHER';
  essential: boolean;
  note?: string;
}

export interface Goal {
  id: string; name: string;
  target: Minor; saved: Minor;
  deadline: ISODate;
  sip?: { monthly: Minor; expectedReturnAnnual: number };  // percent, e.g. 12
  contributions: { date: ISODate; amount: Minor }[];
}

export interface DebtAmortization {
  debtId: string; name: string;
  principal: Minor; apr: number; tenureMonths: number; minPayment: Minor;
  schedule: { n: number; date: ISODate; emi: Minor; interest: Minor; principal: Minor; balance: Minor }[];
}

export interface SecurityAuditLog {
  seq: number;                               // monotonic, starts at 1
  ts: ISODate;
  type: 'AUTH_REGISTER' | 'AUTH_LOGIN_OK' | 'AUTH_LOGIN_FAIL' | 'PIN_FAIL' | 'VAULT_LOCKOUT'
      | 'VAULT_UNLOCK' | 'AUTO_LOCK' | 'DATA_EXPORT' | 'DATA_WIPE' | 'LOG_INTEGRITY_FAIL';
  severity: 'INFO' | 'WARN' | 'ALERT' | 'CRITICAL';
  detail: Record<string, string | number | boolean>;   // never contains secrets
  prevHash: string;                          // hex SHA-256
  hash: string;                              // SHA-256(prevHash || canonical(entry))
}
```

4.2 Persisted State Envelope

```
interface VaultEnvelope {
  v: 1;
  salt: string;             // PBKDF2 salt (base64)
```

(c) 2026 FinPilot Engineering. All rights reserved.

```
  iv: string;               // AES-GCM 96-bit nonce, unique per write
  iterations: number;
  ciphertext: string;       // AES-256-GCM(JSON(AppState)), includes auth tag
}
interface AppState { profile: UserProfile; accounts: LinkedAccount[]; transactions: Transaction[];
  goals: Goal[]; debts: DebtAmortization[]; holdings: Holding[]; invoices: Invoice[];
  audit: SecurityAuditLog[]; schemaVersion: number; }
```

4.3 Invariants

ID	Invariant
INV-1	Sum of account balances minus liabilities equals reported net worth within 1 minor unit.
INV-2	Amortization final balance equals 0 after the adjusted last instalment.
INV-3	Audit sequence numbers are contiguous and each prevHash equals the previous entry hash.
INV-4	Goal saved amount equals the sum of its contributions.
INV-5	No plaintext credential, PIN or key material is present in persisted state or logs.

(c) 2026 FinPilot Engineering. All rights reserved.

5. Security, Privacy & Compliance

5.1 Client-Side Data Segregation

- All user data is persisted only as an AES-256-GCM ciphertext envelope; the key is derived from the PIN with PBKDF2-HMAC-SHA256 (at least 310,000 iterations) and a per-user random salt, and is held in memory only while unlocked.
- A fresh 96-bit IV is generated for every write. GCM authentication detects ciphertext tampering.
- Multi-user separation: each profile uses its own storage namespace, salt and key; there is no shared plaintext index.
- Locking zeroises the in-memory key reference and clears decrypted state from the store.

5.2 Biometric Session Protection

Where the device offers a platform authenticator, FIA can gate session resume with **WebAuthn** user verification (fingerprint / face / device PIN). Biometric templates are handled entirely by the operating system; FinPilot receives only a pass/fail assertion and never stores biometric data. The biometric step **re-authorises session resume** and does not replace the PIN for first unlock after a cold start.

5.3 Zero Telemetry Leakage

- No third-party analytics, advertising or session-replay scripts are bundled.
- A strict Content-Security-Policy (default-src 'self'; connect-src limited to the same origin) blocks unexpected exfiltration.
- Server access logs record method, path and status only; query parameters containing symbols are the sole user-derived data, and request bodies are never logged.
- Audit and error objects are redacted through an allow-list serialiser.

5.4 OWASP Top 10 (2021) Alignment

Category	Control in FinPilot AI
A01 Broken Access Control	Route guard on every view; vault must be unlocked; server exposes no user-scoped data
A02 Cryptographic Failures	AES-256-GCM, PBKDF2-SHA256, Web Crypto only (no custom crypto), TLS 1.2+ in transit
A03 Injection	Schema validation on all input; React escaping; no dynamic HTML or eval; symbol allow-list on API
A04 Insecure Design	Threat-modelled architecture; deterministic engine; numeric guard for AI output
A05 Security Misconfiguration	Helmet headers, CSP, CORS allow-list, production-only build flags
A06 Vulnerable Components	Lockfile, `npm audit` in CI, SBOM generation, pinned versions
A07 Identification & Auth Failures	Password and PIN policy, lockout with back-off, auto-lock, WebAuthn
A08 Software & Data Integrity	Hash-chained audit log, GCM integrity, Subresource Integrity for static assets
A09 Logging & Monitoring Failures	Tamper-evident audit log, server health and rate-limit metrics
A10 SSRF	Proxy contacts only a configured provider host; no user-supplied URLs are fetched

5.5 Privacy & Regulatory Mapping

Principle	Design response
Data minimisation (GDPR Art. 5, India DPDP Act)	Local-first storage; server holds no personal financial data
Right to erasure / portability	One-action secure wipe and encrypted/JSON export (both audit-logged)

(c) 2026 FinPilot Engineering. All rights reserved.

Principle	Design response
Purpose limitation	Quote proxy receives ticker symbols only
Auditability (financial institutions)	Deterministic, reproducible calculations; exportable verification log

> **NOTE:** Local-first storage places responsibility for device security and backups with the user or institution. Losing the PIN means the vault cannot be recovered by design; there is no back door.

5.6 Threat Summary

Threat	Likelihood	Impact	Mitigation
Stolen device, offline attack	Medium	High	PBKDF2 cost, PIN lockout, GCM; recommend OS disk encryption
XSS	Low	High	CSP, escaping, no inline scripts
Quote feed manipulation	Low	Medium	Provider allow-list, TLS, sanity bounds on price jumps
LLM hallucination	Medium	High	Tool-grounded numbers, numeric guard, deterministic fallback
Audit log tampering	Low	High	Hash chain, integrity verification on load

(c) 2026 FinPilot Engineering. All rights reserved.

6. Installation, Deployment & Operation Manual

6.1 Prerequisites

Component	Requirement
Node.js	20 LTS or newer
Package manager	npm 10+
Browser	Evergreen Chrome, Edge, Firefox or Safari (Web Crypto required; Web Speech for voice: Chromium / Safari)
Server	1 vCPU, 512 MB RAM minimum; outbound HTTPS to the market data provider
TLS	Valid certificate; HTTPS mandatory in production (required for Web Crypto, WebAuthn and microphone)

6.2 Environment Variables

Variable	Required	Default	Description
PORT	No	3000	HTTP listen port
NODE_ENV	Yes	development	Set to `production` for deployments
QUOTE_PROVIDER_URL	Yes	-	Base URL of the upstream market-data API
QUOTE_API_KEY	Yes	-	Provider credential (server-side only, never sent to client)
QUOTE_CACHE_TTL_MS	No	5000	Quote cache lifetime
SSE_HEARTBEAT_MS	No	15000	SSE keep-alive interval
CORS_ORIGIN	Yes (prod)	-	Comma-separated allow-list of origins
RATE_LIMIT_PER_MIN	No	120	Requests per IP per minute
VITE_IDLE_LOCK_MIN	No	5	Client default idle-lock timeout
VITE_FIA_LLM_ENABLED	No	false	Enables optional hosted phrasing model

```
# .env.production (never commit)
NODE_ENV=production
PORT=8080
QUOTE_PROVIDER_URL=https://marketdata.example.com/v1
QUOTE_API_KEY=__set_in_secret_manager__
CORS_ORIGIN=https://finpilot.example.com
```

6.3 Build Pipeline

```
git clone <repository-url> finpilot-ai && cd finpilot-ai
npm ci                    # reproducible install from lockfile
npm run lint              # ESLint + TypeScript strict type-check
npm run test              # unit tests for financialEngine.ts and validators
npm run build             # Vite production bundle to /dist
npm audit --omit=dev      # dependency vulnerability gate
```

Stage	Gate	Failure action
Lint / typecheck	Zero errors	Block merge
Unit tests	100% pass; engine coverage target 95%	Block merge
Build	Bundle emitted, size budget respected	Block release
Audit	No high/critical advisories	Block release

6.4 Production Deployment

```
# Option 1: Direct Node runtime
```

(c) 2026 FinPilot Engineering. All rights reserved.

```
npm run build
NODE_ENV=production node server/index.js

# Option 2: Process manager
npm i -g pm2
pm2 start server/index.js --name finpilot --env production
pm2 save && pm2 startup

# Option 3: Container
docker build -t finpilot-ai:2.4.0 .
docker run -d --name finpilot -p 8080:8080 --env-file .env.production finpilot-ai:2.4.0
```

TIP: Place a reverse proxy (Nginx, Caddy or a cloud load balancer) in front of Node. For SSE, disable response buffering (`proxy_buffering off;`) and set the read timeout above the heartbeat interval.

6.5 Operations

Task	Procedure
Health check	`GET /api/health` returns status, uptime and upstream reachability
Rollout	Blue/green or rolling; static assets are content-hashed so old clients keep working
Rollback	Redeploy previous image tag; client data is versioned by `schemaVersion` and migrated forward only
Secret rotation	Rotate QUOTE_API_KEY in the secret manager and restart; no client impact
Monitoring	Alert on 5xx rate, SSE connection drops, upstream latency, and rate-limit hits

WARNING: Never expose QUOTE_API_KEY through a `VITE_`-prefixed variable. Anything with that prefix is embedded in the public client bundle.

(c) 2026 FinPilot Engineering. All rights reserved.

7. User Guide & Walkthrough

7.1 Step-by-Step Walkthrough

Step	Action	Expected input	Expected output
1	Register	Username (3-32), valid email, password 6+ alphanumeric with a letter and digit, 4-8 digit PIN	Account created; vault initialised; AUTH_REGISTER logged
2	Unlock	PIN	Dashboard loads; FHS and cashflow cards render
3	Add accounts and transactions	Institution, balance; date, amount, category	Cashflow chart and savings rate update immediately
4	Review Health Score	None	Score 0-100 with four sub-scores and formula tooltips
5	Add holdings	Symbol, quantity, unit cost	Live value and P&L; stream indicator shows LIVE or STALE
6	Create a goal	Name, target, deadline, expected return	Required SIP, funded %, projected completion
7	Run the Debt Optimizer	Debts (balance, APR, min), extra payment	Snowball vs. avalanche months and interest comparison
8	SME mode: create invoice	Customer, items, tax rate, due date	Invoice with CGST/SGST or IGST; GST ledger updates
9	Ask FIA	'Can I afford a 900,000 car at 9% over 5 years with 150,000 down?'	Verdict, EMI, post-purchase DTI, runway, savings rate
10	Open Scenario Lab	Income drop 30% for 6 months	Survival horizon, FHS delta, side-by-side chart
11	Lock / Export	Click Lock; or Settings, Export	Vault locked; encrypted export file downloaded

7.2 Example: FIA Affordability Query

```
User : Can I afford a 900000 car at 9% for 60 months with 150000 down?
FIA  : [tool: affordability]  principal=750000  EMI=15569 (computed)
       Verdict: CAUTION
       - Debt-to-income after purchase: 0.41 (limit 0.40)  -> fails
       - Emergency runway after down payment: 3.2 months (min 3.0) -> passes
       - Savings rate after EMI: 0.14 (min 0.10) -> passes
       Option: extend tenure to 72 months (EMI 13,519) to bring DTI to 0.39.
```

NOTE: The example is illustrative of the response format. Actual figures depend entirely on the profile entered.

7.3 Troubleshooting FAQ

Issue	Likely cause	Resolution
Registration rejected	Email format or password policy not met	Use a valid address; include at least one letter and one digit, 6+ characters, no symbols
'Vault locked' after several attempts	5 failed PIN entries	Wait for the displayed cool-down. The PIN cannot be reset without data loss
Forgot PIN	Key is derived from PIN; no recovery by design	Restore from an encrypted export if available; otherwise wipe and re-register
Prices show STALE	SSE disconnected, provider delay or network issue	Check connectivity; the client retries automatically; verify /api/health

(c) 2026 FinPilot Engineering. All rights reserved.

Issue	Likely cause	Resolution
Voice input not working	Microphone permission denied or unsupported browser	Allow microphone in browser settings; use Chrome, Edge or Safari over HTTPS
FIA reply uses a templated sentence	Numeric guard rejected the narrated draft	Expected safe fallback; figures remain correct
Scores differ from another tool	Different formula or weighting	Open the formula tooltip; FinPilot formulas are documented in Section 3, Module B
GST totals look off	Wrong tax code or intra/inter-state flag	Edit the invoice tax settings; ledger recalculates
Data missing on another device	Local-first storage is device-bound	Use Export and Import with the same PIN

7.4 Glossary

Term	Meaning
FHS	Financial Health Score
FIA	Financial Intelligence Agent
DTI	Debt-to-Income ratio
SIP	Systematic Investment Plan
EMI	Equated Monthly Instalment
ITC	Input Tax Credit
SSE	Server-Sent Events
PBKDF2	Password-Based Key Derivation Function 2
GCM	Galois/Counter Mode authenticated encryption

7.5 Disclaimer

FinPilot AI provides analytical information derived from user-supplied data and delayed market feeds. It does not provide regulated investment, tax or legal advice. Users and institutions should verify outputs with qualified professionals before acting.

End of Document - FP-TDR-2.4.0-001

(c) 2026 FinPilot Engineering. All rights reserved.